

Policy_ID: CIP-ISP-001

Policy_Name: Information Security & Data Protection

Policy Version: 3.4

Effective_Date: 2025-11-01

Risk_Category: Security Applicable_Regulations: [ISO 27001, SOC 2, HIPAA, GDPR]

Owner: Chief Information Security Officer (CISO)

Information Security & Data Protection Policy

1. Purpose & Scope [Risk Score: 1]

This policy ensures the confidentiality, integrity, and availability of Capstone information assets. It applies to all employees, contractors, and third parties accessing corporate systems.

2. Roles & Responsibilities [Risk Score: 2]

- **CISO:** Owns policy and monitors incidents.
- **Department Heads:** Approve access requests only when justified.
- **Employees:** Protect credentials and devices; report incidents promptly.

Non-Compliance Impact: Negligence in role-based responsibilities is a **Medium Risk** performance issue.

3. Data Classification [Risk Score: 4]

Data must be classified into four tiers:

1. **Public:** Safe for release.
2. **Internal:** Operational use.
3. **Confidential:** Financial/Legal/HR data.
4. **Restricted:** PII, Client Data, Regulated Data.

Non-Compliance Impact: Mishandling "Restricted" data on unapproved channels is a **High Risk** violation.

4. Access Control [Risk Score: 5]

- **Least Privilege:** Access granted strictly on need-to-know basis.
- **MFA:** Mandatory for all privileged access.
- **Deprovisioning:** Terminated user access must be revoked within **4 hours**.

Non-Compliance Impact: Sharing passwords or failing to revoke access for terminated staff is a **Critical Risk** (Score 5) security breach.

5. Security Controls [Risk Score: 5]

- **Encryption:** AES-256 for data at rest; TLS 1.2+ for transit.
- **Endpoint:** EDR agent mandatory on all devices; automatic lockdown if tampered.
- **Network:** Zero-Trust segmentation; no direct SSH/RDP without VPN.
- **Patching:** Critical patches applied within **72 hours**.

Non-Compliance Impact: Disabling endpoint protection (EDR) is a **Critical Risk** violation treated as potential malicious activity.

6. Incident Response [Risk Score: 5]

- **Reporting:** Incidents must be reported to security@capstone.inc within **30 minutes**.
- **Process:** Follows Identification -> Containment -> Eradication -> Recovery.

Non-Compliance Impact: Failure to report a security incident within the 30-minute SLA is a **Critical Risk** violation.

7. Financial Impact [Risk Score: 3]

Security incidents have direct costs:

- **Ransomware Downtime:** Estimated at **\$8,000 per hour**.
- **Penalties:** Up to \$250,000 per violation.
- **Reserve:** \$500,000 annual breach compensation fund.

Non-Compliance Impact: Actions leading to financial loss due to negligence may result in restitution claims against the employee (High Risk).